

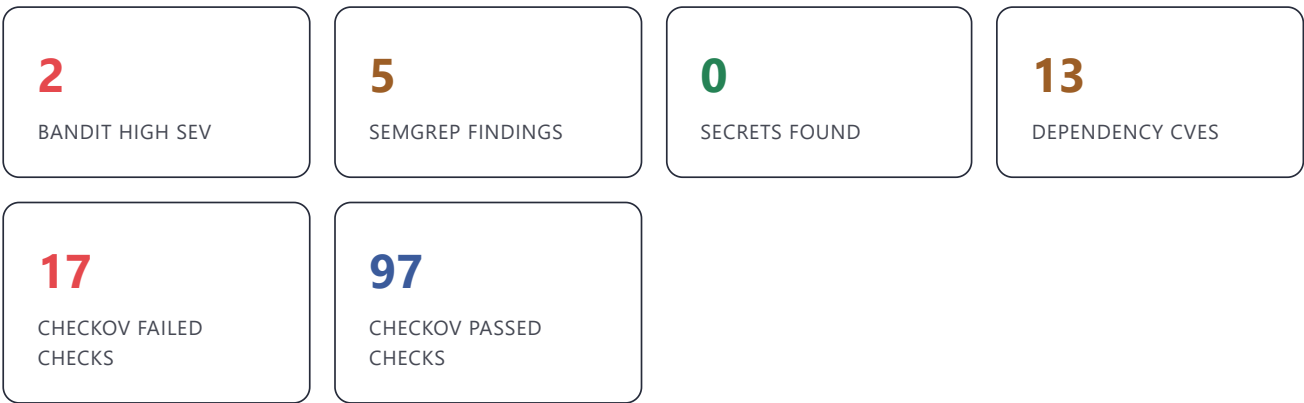
SecureApp Pipeline — Security Report

Generated 2026-08-09 · Consolidated from Bandit, Semgrep, detect-secrets, pip-audit, Checkov, SBOM

OverviewSASTSecretsDependenciesInfrastructureSBOM

Overview

High-level counts across all scans run against this repo



SAST — Bandit

Static analysis of src/ · 422 lines scanned · 2 high, 2 medium, 1 low

SEVERITY	CONFIDENCE	RULE	LOCATION	ISSUE
LOW	MEDIUM	B105 hardcoded_password_string	src/app/__init__.py:17	Possible hardcoded password: 'super_secret_key_12345'
HIGH	HIGH	B324 hashlib	src/app/routes/auth.py:26	Use of weak MD5 hash for security. Consider usedforsecurity=False
MEDIUM	LOW	B608 hardcoded_sql_expressions	src/app/routes/auth.py:59	Possible SQL injection vector through string-based query construction.
HIGH	HIGH	B324 hashlib	src/database/init_db.py:42	Use of weak MD5 hash for security. Consider usedforsecurity=False
MEDIUM	MEDIUM	B104 hardcoded_bind_all_interfaces	src/wsgi.py:26	Possible binding to all interfaces.

SAST — Semgrep

Custom ruleset (scripts/semgrep-rules.yml) · community registry packs (p/python, p/flask, p/secrets) were skipped — no network access to the Semgrep registry from this environment

SEVERITY	RULE	LOCATION	MESSAGE
ERROR	scripts.hardcoded-secret-key	src/app/__init__.py:17	Hardcoded secret/API key/password detected in source (CWE-798). Load from an environment variable or secrets manager instead.
ERROR	scripts.jwt-decode-missing-algorithms-allowlist	src/app/routes/api.py:44	jwt.decode() should pin an explicit, minimal algorithms allowlist (e.g. algorithms=["HS256"]). Accepting "none" or multiple mismatched algorithm families enables algorithm-confusion attacks (CWE-347).
WARNING	scripts.weak-hash-md5-sha1	src/app/routes/auth.py:26	MD5/SHA1 are cryptographically broken for password hashing (CWE-327/916). Use bcrypt, scrypt, argon2, or werkzeug.security.generate_password_hash.
ERROR	scripts.sql-injection-fstring	src/app/routes/auth.py:59	Possible SQL Injection: SQL query built with an f-string / string concatenation instead of parameterized query placeholders (?). See CWE-89. Use `conn.execute("... WHERE x = ?", (value,))` instead.
WARNING	scripts.weak-hash-md5-sha1	src/database/init_db.py:42	MD5/SHA1 are cryptographically broken for password hashing (CWE-327/916). Use bcrypt, scrypt, argon2, or werkzeug.security.generate_password_hash.

Note: only the custom ruleset ran. Re-run `bash scripts/run-level1-checks.sh` locally to include the full p/python, p/flask, and p/secrets registry packs.

Secret Scanning — detect-secrets

Baseline scan across the repository

No secrets detected.

Dependency CVEs — pip-audit

13 known vulnerabilities found across src/requirements.txt · severity gate: PASSED (no HIGH/CRITICAL flagged; OSV severity data unavailable for these advisories — review fix versions below)

PACKAGE	ADVISORY	FIX VERSION(S)
flask==3.0.3	PYSEC-2026-2151 CVE-2026-27205, GHSA-68rp-wp8r-4726	3.1.3
pyjwt==2.9.0	PYSEC-2026-120 CVE-2026-32597, GHSA-752w-5fwx-jx9f	2.12.0
pyjwt==2.9.0	PYSEC-2025-183 CVE-2025-45768	none published

PACKAGE	ADVISORY	FIX VERSION(S)
pyjwt==2.9.0	PYSEC-2026-179 CVE-2026-48526, GHSA-xgmm-8j9v-c9wx	2.13.0
pyjwt==2.9.0	PYSEC-2026-175 CVE-2026-48522, GHSA-993g-76c3-p5m4	2.13.0
pyjwt==2.9.0	PYSEC-2026-177 CVE-2026-48524, GHSA-fhv5-28vv-h8m8	2.13.0
pyjwt==2.9.0	PYSEC-2026-178 GHSA-w7vc-732c-9m39, CVE-2026-48525	2.13.0
pyjwt==2.9.0	PYSEC-2026-176 GHSA-jq35-7prp-9v3f, CVE-2026-48523	2.12.1
werkzeug==3.0.4	PYSEC-2026-2045 GHSA-f9vj-2wh5-fj8j, CVE-2024-49766	3.0.6
werkzeug==3.0.4	PYSEC-2026-2046 CVE-2025-66221, GHSA-hgf8-39gv-g3f2	3.1.4
werkzeug==3.0.4	PYSEC-2026-2044 CVE-2026-21860, GHSA-87hc-h4r5-73f7	3.1.5
werkzeug==3.0.4	PYSEC-2026-2320 CVE-2026-27199, GHSA-29vq-49wr-vm6x	3.1.6
werkzeug==3.0.4	PYSEC-2026-3417 CVE-2024-49767, GHSA-q34m-jh98-gwm2	3.0.6

Safety CLI cross-check was skipped (requires interactive `safety auth login`).

Infrastructure — Checkov

38 Terraform resources scanned · 97 passed / 17 failed

CHECK ID	DESCRIPTION	RESOURCE	FILE
CKV_AWS_158	Ensure that CloudWatch Log Group is encrypted by KMS	<code>aws_cloudwatch_log_group.app_logs</code>	<code>/terraform/cloudwatch.tf</code>
CKV_AWS_338	Ensure CloudWatch log groups retains logs for at least 1 year	<code>aws_cloudwatch_log_group.app_logs</code>	<code>/terraform/cloudwatch.tf</code>

CHECK ID	DESCRIPTION	RESOURCE	FILE
CKV_AWS_88	EC2 instance should not have public IP.	aws_instance.app	/terraform/ec2.tf
CKV_AWS_135	Ensure that EC2 is EBS optimized	aws_instance.app	/terraform/ec2.tf
CKV_AWS_300	Ensure S3 lifecycle configuration sets period for aborting failed uploads	aws_s3_bucket_lifecycle_configuration.access_logs	/terraform/s3.tf
CKV_AWS_382	Ensure no security groups allow egress from 0.0.0.0:0 to port -1	aws_security_group_rule.egress_all	/terraform/security_groups.tf
CKV_AWS_158	Ensure that CloudWatch Log Group is encrypted by KMS	aws_cloudwatch_log_group.vpc_flow_logs	/terraform/vpc.tf
CKV_AWS_338	Ensure CloudWatch log groups retains logs for at least 1 year	aws_cloudwatch_log_group.vpc_flow_logs	/terraform/vpc.tf
CKV2_AWS_64	Ensure KMS key Policy is defined	aws_kms_key.reports	/terraform/s3.tf
CKV_AWS_21	Ensure all data stored in the S3 bucket have versioning enabled	aws_s3_bucket.access_logs	/terraform/s3.tf
CKV2_AWS_62	Ensure S3 buckets should have event notifications enabled	aws_s3_bucket.reports	/terraform/s3.tf
CKV2_AWS_62	Ensure S3 buckets should have	aws_s3_bucket.access_logs	/terraform/s3.tf

CHECK ID	DESCRIPTION	RESOURCE	FILE
	event notifications enabled		
CKV2_AWS_12	Ensure the default security group of every VPC restricts all traffic	aws_vpc.main	/terraform/vpc.tf
CKV_AWS_145	Ensure that S3 buckets are encrypted with KMS by default	aws_s3_bucket.access_logs	/terraform/s3.tf
CKV2_AWS_61	Ensure that an S3 bucket has a lifecycle configuration	aws_s3_bucket.reports	/terraform/s3.tf
CKV_AWS_144	Ensure that S3 bucket has cross-region replication enabled	aws_s3_bucket.reports	/terraform/s3.tf
CKV_AWS_144	Ensure that S3 bucket has cross-region replication enabled	aws_s3_bucket.access_logs	/terraform/s3.tf

tfsec and terraform fmt/validate were not run — those binaries aren't available in this environment (no network access to fetch them). Run `bash scripts/run-level5-checks.sh` locally for the complete Level 5 report.

Software Bill of Materials

4 components · CycloneDX format

NAME	VERSION	TYPE	PACKAGE URL
Flask	3.0.3	library	pkg:pypi/flask@3.0.3
PyJWT	2.9.0	library	pkg:pypi/pyjwt@2.9.0
Werkzeug	3.0.4	library	pkg:pypi/werkzeug@3.0.4

NAME	VERSION	TYPE	PACKAGE URL
prometheus-client	0.20.0	library	pkg:pypi/prometheus-client@0.20.0